Securing cloud environments: a defense-in-depth approach with OCI WAF

Introduction

Cybersecurity risks continue to threaten organizations worldwide, including state and local governments. Web applications are frequent targets for malicious actors, making their security a critical component of an organization's overall defense strategy. A compromised web server can lead to severe consequences, including reputational damage, financial losses, and data breaches. Prioritizing web application security helps mitigate these risks and strengthens an organization's cybersecurity posture.

Designing Secure Cloud Architectures

Cloud-hosted environments require careful security considerations at the architectural design stage. Government organizations must adopt a **defense-in-depth** strategy—an approach that layers multiple security measures to protect critical assets. This ensures that if one defense layer is compromised, additional safeguards remain in place to mitigate threats.

Alongside defense-in-depth, organizations should implement a **deny-by-default** security model. This strategy blocks all inbound and outbound traffic unless explicitly allowed by firewall policies, minimizing exposure to unauthorized access.

This blog will walk through the process of configuring a load balancer for a web server hosted on an OCI compute instance and securing it with OCI Web Application Firewall (WAF) as part of a comprehensive security strategy.

OCI's Built-In Security for Cloud Environments

Oracle Cloud Infrastructure (OCI) provides integrated security features designed to strengthen cloud environments. Security is embedded into OCI's foundation, with web application firewalls (WAF) playing a crucial role in protecting applications from evolving cyber threats.

Common Web Application Attacks

To effectively secure web applications, it is essential to understand common attack vectors. Some of the most prevalent threats include:

- DDoS Attacks (Distributed Denial-of-Service) - DDoS attacks aim to disrupt the normal operation of a server, service, or network by overwhelming it with excessive traffic. Attackers flood the target with requests, exhausting its resources and causing service disruptions.

- SQL Injection - SQL injection is a web security vulnerability that allows attackers to manipulate an application's database queries. By injecting malicious SQL statements, attackers can gain unauthorized access to sensitive data, alter records, or even delete entire databases.

- Cross-Site Scripting (XSS) - XSS attacks enable attackers to inject malicious scripts into trusted websites. These scripts can hijack user sessions, steal sensitive data, or execute unauthorized actions on behalf of the user, posing significant security risks.

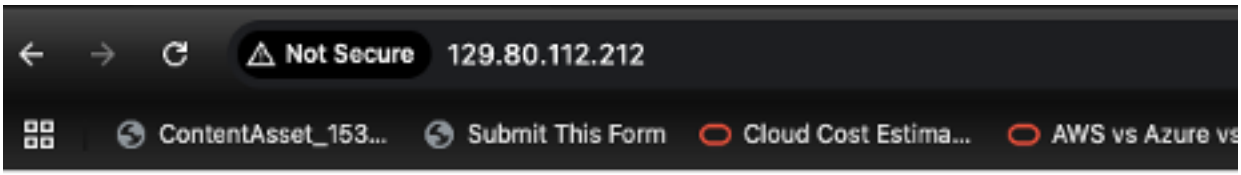
Mitigating Risks with OCI Web Application Firewall (WAF)

State and local governments can enhance their web security posture by deploying OCI WAF in front of their web applications. OCI WAF helps protect against DDoS, SQL injection, XSS, and other web-based threats by filtering malicious traffic and enforcing security policies.

Example Deployment: Securing a Web Server with OCI WAF

In this example, I have deployed an Apache web server on an OCI compute instance. When setting up your instance, it is critical to configure Virtual Cloud Network (VCN) settings properly to allow secure Internet access. OCI WAF is then deployed to inspect and filter incoming traffic, ensuring only legitimate requests reach the application.

By implementing defense-in-depth security measures and leveraging OCI's cloud-native security tools, organizations can proactively mitigate threats and strengthen the security of their web applications.



Welcome to the Apache Webserver!

After deploying the web server, the next step is to set up a load balancer and attach the compute instance as a backend server. This configuration enhances high availability and ensures seamless traffic distribution for your web application.

Once the compute instance is added as a backend, you can access your web application by navigating to the load balancer's public IP address or its assigned domain name. This setup helps distribute traffic efficiently, improving performance, reliability, and fault tolerance for your cloud-hosted application.

After setting up the load balancer, the next step is to create a WAF policy. This is where you define access control rules to filter and protect incoming traffic.

With OCI WAF, you can:

- Block or allow traffic based on IP addresses, geolocation, or specific request patterns.
- Mitigate DDoS attacks, SQL injection, and cross-site scripting (XSS) threats.

- Enforce rate limiting to prevent abuse and excessive requests.

Once the WAF policy is configured and applied to your load balancer, it serves as an additional security layer, ensuring only legitimate requests reach your web application.

Defining Countries' Access in Access Control Rules

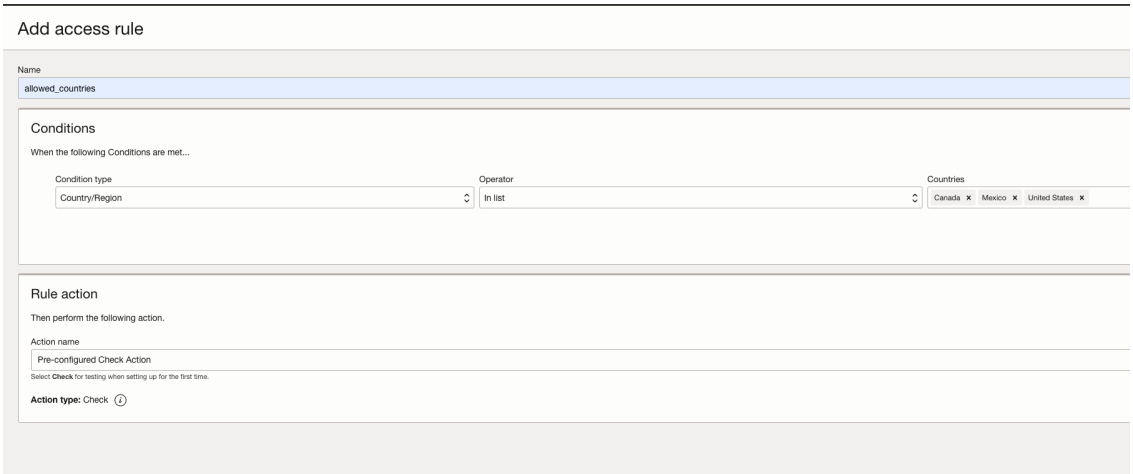
Next, add an access control rule to your WAF policy to limit incoming traffic to the web server only from countries in North America.

Steps to Configure the Access Control Rule:

1. Navigate to OCI WAF and select your WAF policy.
2. Go to the Access Control Rules section and create a new rule.

3. Set the rule conditions:
    - Geolocation-based filtering: Allow only traffic originating from North America (United States, Canada, and Mexico).
4. Set the rule action: Choose Preconfigured Check Action **to** log traffic that does not meet the rule conditions without blocking execution.
5. Apply and save the policy.

This configuration ensures that non-North American traffic is logged for monitoring and analysis while still allowing unrestricted access within the defined region.



Here is the result shown when a client tries to connect outside of the established countries.

This access control rule helps reduce the threat scope by restricting access to only predefined countries in North America**.** By doing so, malicious attackers from outside the approved region are unable to reach the web application, minimizing potential attack vectors.

Additionally, since the rule is configured as a preconfigured check action, it does not block traffic but logs unauthorized access attempts. This allows security teams to analyze trends, identify potential threats, and fine-tune security policies without immediately disrupting traffic.

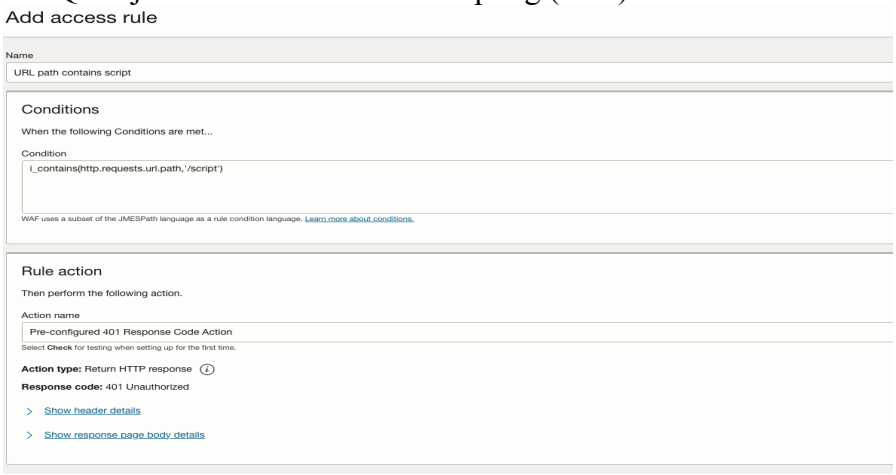
SQL Injection Mitigation

To mitigate SQL Injection attacks, OCI Web Application Firewall (WAF) enables users to define rules that restrict specific inputs from being included in a website's URL path.

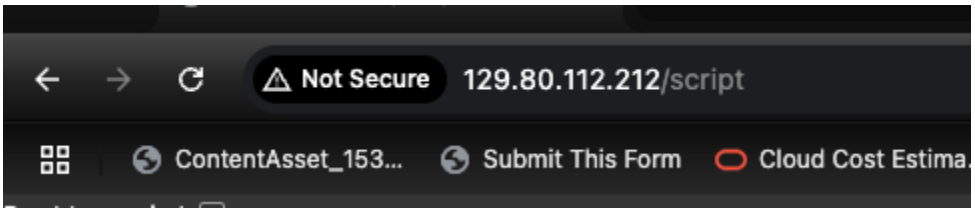
In this example, an access rule is created to detect and block potentially malicious requests:

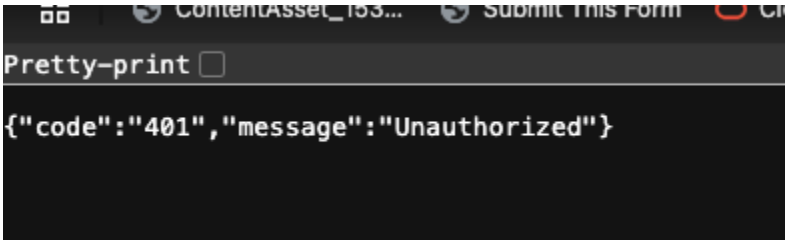
- Condition: If the URL path contains the keyword "script" (often used in injection attacks).
- Action: The request is denied with an HTTP 401 Unauthorized response.

This proactive rule helps prevent malicious queries from reaching the backend, reducing the risk of SQL Injection and Cross-Site Scripting (XSS) attacks.



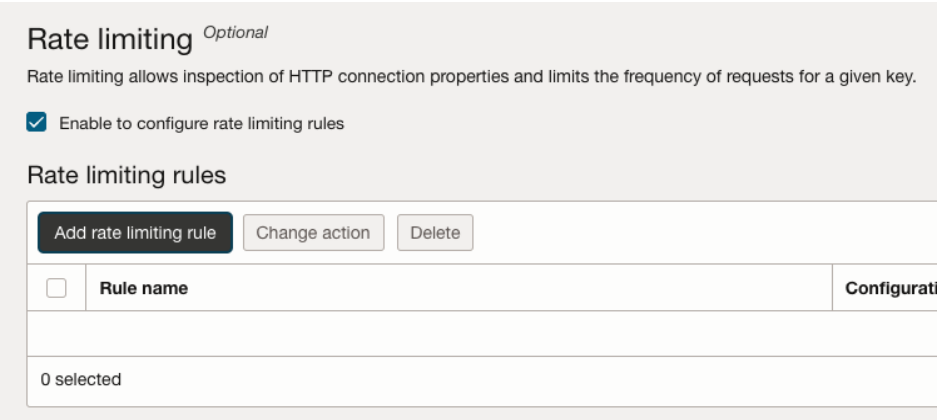
When accessing the Load Balancer's IP address with ‘script’ appended to the URL, the following result is observed.



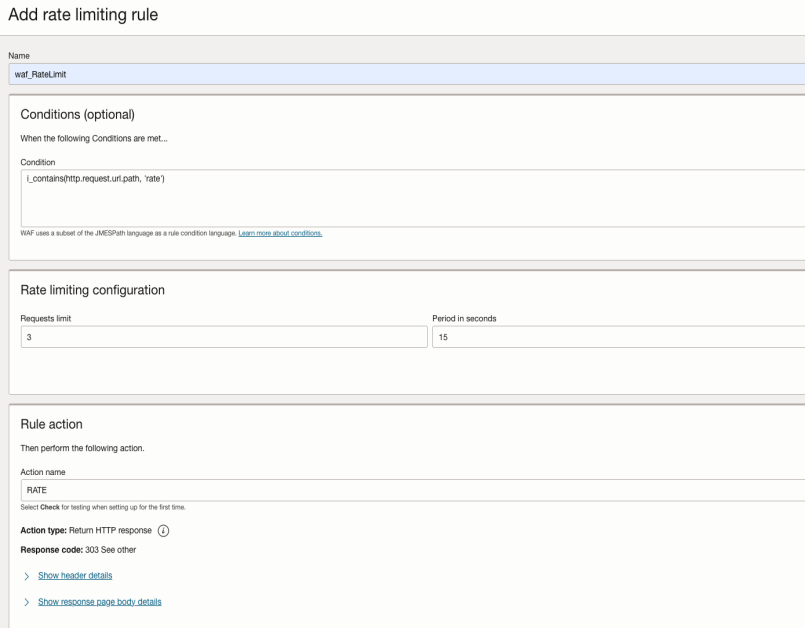


Combatting DDoS Attacks with Rate Limiting

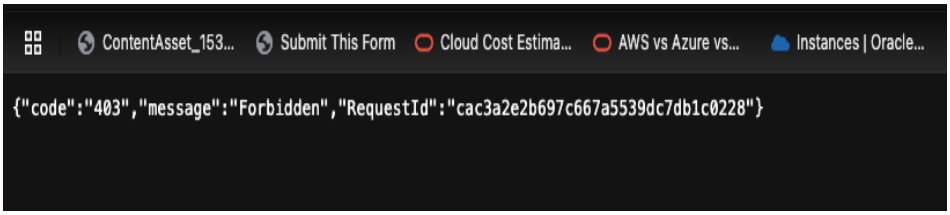
Next, let’s define rate limiting rules to protect against DDoS attacks. Ensure to select ‘Enable to configure rate limiting rules.



In this example, a client is not allowed to attempt to access the web server more than 3 times in an interval of 15 seconds. If this happens, they will be redirected to a 303 HTTP response.

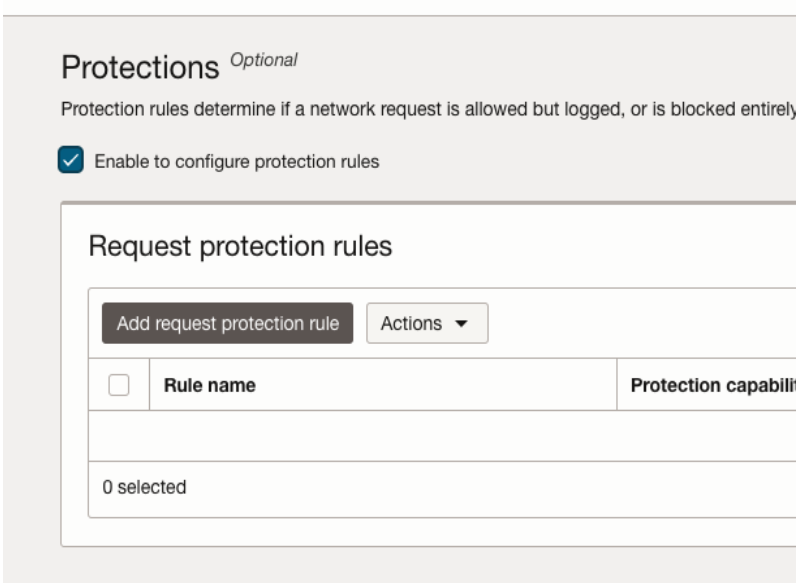


Here is the output of the action where a client attempts to connect to the load balancer 3 times:

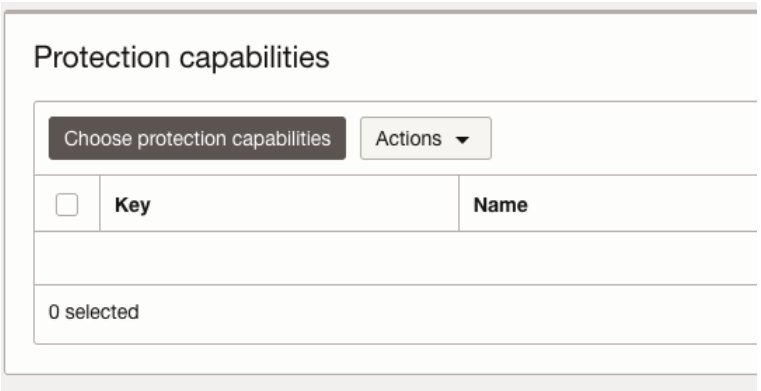


Using Protection Rules to Combat Cross Site Scripting Attacks

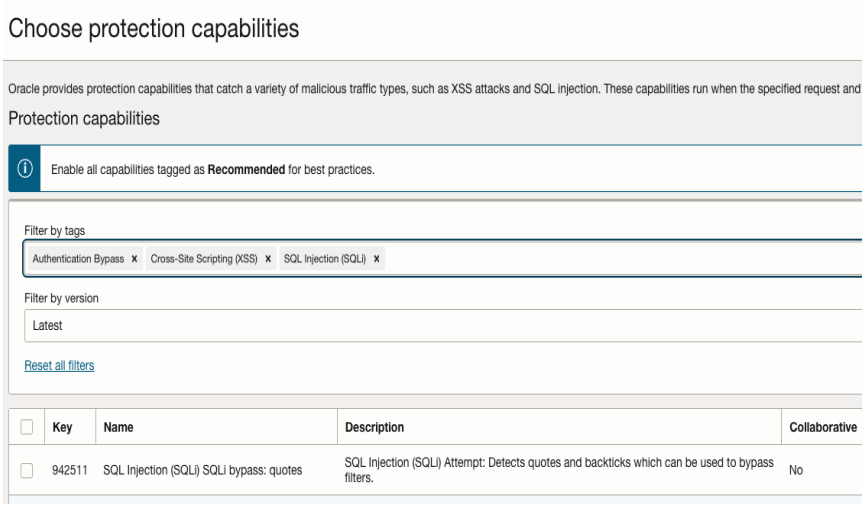
Next, let's add some protection rules to block common web application attacks, such as Cross Site Scripting



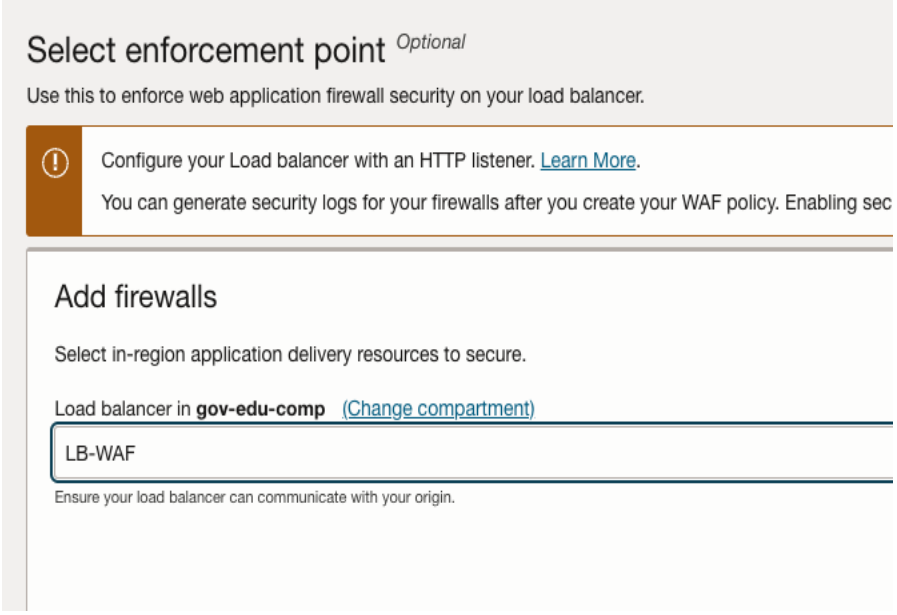
Next, let's add protection rules to include OWASP's Top 10 vulnerabilities.



We are going to select Cross Site Scripting and SQL Injection protection capabilities.



After the creation of the WAF, users must attach it to a domain name or load balancer. In our example, we are attaching it to a load balancer.



When the WAF has been attached to the load balancer, you can navigate to your load balancer and view that it has successfully been attached in the load balancer's details.

Web application firewall	webappfirewall20250211183723
Network security groups	—

Summary

Organizations must continuously prioritize web security in OCI to stay ahead of evolving web application threats. For government entities, maintaining a proactive security posture is critical. By leveraging OCI WAF and other built-in security features, they can establish a robust, cloud-native defense against modern cyber threats. Adopting a security-first approach in cloud application design helps prevent costly breaches, financial losses, and reputational damage.